

UD4 - Fortificación de Hosts

Medidas para reducir la superficie de ataque, proteger sistemas operativos y detectar incidentes.

Datos de la unidad	Información
Módulo	Seguridad y Alta Disponibilidad
Curso	2.º ASIR
Modalidad	Semipresencial
Duración	14 horas

Índice

1. [Fundamentos del hardening](#)
2. [Identidades, permisos y acceso remoto](#)
3. [Arranque seguro y protección de datos](#)
4. [Protección frente al malware](#)
5. [Actualizaciones, auditoría y vulnerabilidades](#)
6. [Monitorización, registros y respuesta](#)
7. [Resumen](#)
8. [Recursos](#)
9. [Relación con los resultados de aprendizaje](#)

1. Fundamentos del hardening

1.1. Introducción

La fortificación, o *hardening*, es el conjunto de medidas que reduce la superficie de ataque de un host y limita el impacto de un posible compromiso. Afecta a servidores, equipos cliente, máquinas virtuales y dispositivos conectados. No consiste en una configuración única: requiere inventario, aplicación de controles, revisión y mejora continua.

Antes de modificar un sistema se debe identificar qué está expuesto: usuarios y grupos, servicios activos, puertos abiertos, aplicaciones instaladas, tareas programadas, interfaces de red, directorios compartidos y versiones de software. El objetivo es eliminar o deshabilitar lo que no aporta una función necesaria.

1.2. Objetivos

Al finalizar la unidad, el alumnado será capaz de:

- Identificar la superficie de ataque de un host.
- Aplicar controles de acceso, permisos y autenticación robusta.
- Proteger el arranque, el almacenamiento y los datos.
- Reconocer medidas de prevención frente al malware.
- Gestionar actualizaciones, auditorías y vulnerabilidades.

- Interpretar registros, alertas y mecanismos de monitorización.

1.3. Principios de fortificación

El principio de mínimo privilegio guía todas las decisiones: cada usuario, servicio y proceso debe disponer solo de los permisos estrictamente necesarios. Ejecutar servicios con privilegios administrativos, compartir cuentas o mantener servicios innecesarios amplía el riesgo y dificulta la investigación posterior.

Una fortificación eficaz combina controles técnicos, políticas documentadas y formación. Las medidas deben ser proporcionadas al riesgo, verificables y compatibles con la continuidad del servicio.

2. Identidades, permisos y acceso remoto

La gestión de identidades determina quién puede acceder a un sistema y a qué recursos. Las cuentas deben ser individuales, tener un responsable y revisarse periódicamente. Las cuentas abandonadas, compartidas o con privilegios excesivos son un riesgo frecuente.

En Linux, los permisos distinguen propietario, grupo y resto de usuarios, con lectura, escritura y ejecución. La asignación de grupos facilita aplicar permisos coherentes a varios usuarios. Configuraciones amplias como permisos universales de escritura o ejecución deben evitarse salvo una necesidad concreta, documentada y controlada.

Las contraseñas deben ser largas, únicas y difíciles de predecir. Una política razonable contempla longitud mínima, protección frente a intentos repetidos, historial cuando sea necesario y un procedimiento seguro de recuperación. Forzar cambios periódicos sin indicios de compromiso puede fomentar patrones predecibles; es preferible exigir el cambio tras sospecha de exposición, recuperación de cuenta o cambio de riesgo. Los gestores de contraseñas y la autenticación multifactor reducen la dependencia de una única contraseña.

La autenticación multifactor combina factores de conocimiento, posesión o inherencia. Un código temporal, una llave de seguridad o un token complementan la contraseña y reducen el impacto de su robo. Los mecanismos de recuperación del segundo factor también deben estar protegidos.

SSH permite administrar hosts Linux de forma remota. Una configuración segura utiliza claves en lugar de depender solo de contraseñas, restringe los usuarios autorizados, limita los privilegios, mantiene el servicio actualizado y registra los accesos. La clave privada nunca se comparte; la pública puede instalarse en el servidor. Antes de aplicar cambios se debe prever una vía de recuperación para no perder el acceso legítimo.

3. Arranque seguro y protección de datos

La protección comienza antes de que arranque el sistema operativo. UEFI, las contraseñas de firmware, la restricción del arranque externo y las actualizaciones de firmware reducen el riesgo de manipulación física. Secure Boot verifica que los componentes de arranque estén firmados por una entidad de confianza. TPM puede medir elementos del arranque y colaborar con mecanismos de protección como BitLocker.

El cifrado de disco protege la confidencialidad de los datos en reposo cuando se pierde, roba o retira un dispositivo. BitLocker se integra en Windows, FileVault en macOS y LUKS es el estándar habitual en Linux. El cifrado no reemplaza los permisos, las copias de seguridad ni la gestión de claves: si la clave de recuperación se pierde, los datos pueden quedar inaccesibles.

También se puede cifrar de forma más granular mediante volúmenes o directorios, por ejemplo con VeraCrypt o EFS en Windows. La elección depende de qué datos se protegen, quién debe acceder a ellos, dónde se almacenan las claves y cómo se realizará la recuperación.

Los datos en tránsito requieren protocolos autenticados y cifrados, como HTTPS, SSH, SFTP o una VPN. Los datos sensibles deben clasificarse, tener controles de acceso adecuados y contar con copias de seguridad cifradas y recuperables. La seguridad física, como control de acceso a instalaciones, anclajes, armarios cerrados o vigilancia, complementa estos controles.

4. Protección frente al malware

El malware es software diseñado para dañar, espiar, interrumpir o acceder sin autorización a un sistema. Entre sus formas más comunes se encuentran virus, gusanos, troyanos, ransomware, spyware, adware, rootkits, *keyloggers*, malware sin archivo y botnets. Pueden entrar mediante phishing, aplicaciones maliciosas, vulnerabilidades sin parchear, redes inseguras o ataques a la cadena de suministro.

La defensa se basa en capas: actualización de sistemas, mínimo privilegio, segmentación de red, filtrado de correo, copias de seguridad probadas, autenticación multifactor, control de aplicaciones y formación de usuarios. Un ransomware puede afectar también a recursos compartidos y copias conectadas, por lo que las copias deben estar separadas y contar con protección frente a modificación no autorizada.

Las soluciones antimalware combinan firmas, heurística y análisis de comportamiento. Un antivirus protege principalmente frente a amenazas conocidas; las soluciones EDR recopilan y analizan actividad de los endpoints para detectar y responder; XDR correlaciona señales de endpoints, red, correo, nube y otros orígenes. Una *sandbox* permite analizar ficheros sospechosos en un entorno aislado, pero nunca justifica ejecutar muestras en un equipo de producción.

Los servicios públicos de análisis pueden ofrecer indicadores útiles, pero subir un archivo revela su contenido a terceros. Los ficheros confidenciales, datos personales, claves o documentos internos no deben enviarse a servicios externos de análisis sin autorización expresa.

5. Actualizaciones, auditoría y vulnerabilidades

Las actualizaciones corrigen vulnerabilidades, errores y problemas de estabilidad. Una política de parcheo debe inventariar activos y versiones, evaluar actualizaciones, probar cambios cuando su impacto sea relevante, desplegarlos de forma controlada y verificar el resultado. En entornos Windows, WSUS o Microsoft Endpoint Configuration Manager permiten centralizar el despliegue; en Linux, los gestores de paquetes y herramientas de automatización cumplen ese papel.

La integridad y procedencia del software deben comprobarse mediante repositorios oficiales, firmas digitales, hashes y control de versiones. Git registra cambios en el código, mientras que las firmas de paquetes o de código ayudan a verificar autoría e integridad. Estas verificaciones no sustituyen la aplicación oportuna de parches.

La gestión de vulnerabilidades es un ciclo continuo: identificación, análisis, priorización, corrección, verificación y seguimiento. La prioridad no depende solo de una puntuación técnica: también importan la exposición del activo, su criticidad, la facilidad de explotación, el impacto y los controles compensatorios disponibles.

Herramientas como Lynis, OpenSCAP y GVM/OpenVAS ayudan a descubrir configuraciones débiles, incumplimientos o vulnerabilidades conocidas. Nessus, Qualys, Rapid7 InsightVM y Tripwire son alternativas comerciales. Cualquier escaneo debe realizarse únicamente sobre activos propios o autorizados, con un alcance y horario definidos para evitar afectar a los servicios.

6. Monitorización, registros y respuesta

Los registros documentan eventos de sistemas, aplicaciones y dispositivos. Permiten detectar actividad anómala, investigar incidentes, demostrar cumplimiento y aprender de los fallos. Una estrategia de registros útil define qué eventos se conservan, durante cuánto tiempo, quién puede consultarlos y cómo se protege su integridad.

En un host se deben vigilar, entre otros aspectos, autenticaciones, cambios de privilegio, inicios y paradas de servicios, errores, conexiones de red, consumo de recursos y cambios de configuración. La monitorización local aporta una primera visión, mientras que la centralización evita que la evidencia se pierda si un host es comprometido.

Un IDS detecta indicios de intrusión; un IPS puede además bloquear tráfico o acciones según su configuración. Snort y Suricata son ejemplos de motores de detección en red. Un SIEM recopila y correlaciona eventos de múltiples fuentes para generar alertas, facilitar investigaciones y producir informes de cumplimiento. Wazuh combina agentes, análisis de logs, detección de cambios e integración con gestión de vulnerabilidades; Elastic Stack y Graylog se utilizan con frecuencia para centralizar y visualizar registros.

Las alertas necesitan un procedimiento de respuesta: validar el evento, clasificar su gravedad, contener el impacto, preservar evidencias, erradicar la causa, recuperar el servicio y documentar las lecciones aprendidas. La revisión continua de reglas, umbrales y falsos positivos mantiene útil el sistema de monitorización.

7. Resumen

La fortificación de hosts reduce la superficie de ataque mediante inventario, mínimo privilegio, autenticación robusta, protección del arranque, cifrado, actualizaciones, defensa frente al malware y monitorización. La mejora continua requiere comprobar los cambios, priorizar vulnerabilidades y documentar las decisiones.

8. Recursos

- [CIS Benchmarks](#)
- [Lynis](#)
- [Wazuh](#)
- [OpenSCAP](#)
- [CISA](#)
- [CCN-CERT](#)

9. Relación con los resultados de aprendizaje

La unidad desarrolla la adopción de prácticas seguras, la protección de hosts y datos, el control de acceso, la detección de amenazas, la actualización de sistemas y la monitorización de la seguridad.